

Healthcare Privacy and HIPAA-Style Guidelines

Synthetic healthcare policy document for RAG testing

Document Notice

This file is synthetic and created only for healthcare AI assistant RAG testing. It does not contain real patient data, PHI, confidential client data, or actual medical advice.

1. Purpose

This document describes privacy expectations for healthcare staff, AI prototypes, and document-based assistants. It is synthetic and does not contain real patient data.

2. Confidentiality

Patient information must be kept confidential and protected. Staff must not share patient records with unauthorized people, public channels, personal devices, or unapproved tools.

- Patient information must be kept confidential and protected.
- Staff must not share patient records with unauthorized people, public channels, personal devices, or unapproved tools.

3. Minimum Necessary Principle

Healthcare workers should access or disclose only the minimum information needed for the assigned task. Extra patient details should not be copied into test systems or demo applications.

4. AI Prototype Rules

AI assistants used for demos or hackathons must not include real patient data, PHI, confidential client records, or private medical histories. Synthetic documents or public healthcare information should be used instead.

- AI assistants used for demos or hackathons must not include real patient data, PHI, confidential client records, or private medical histories.
- Synthetic documents or public healthcare information should be used instead.

5. Allowed Data

Allowed data includes synthetic policies, public education content, de-identified sample text, generic FAQs, and mock appointment records. These materials should not identify real patients.

6. Security Controls

Systems should use environment variables for secrets, avoid hardcoded API keys, restrict logs from storing sensitive input, and use secure channels where appropriate.

- Systems should use environment variables for secrets, avoid hardcoded API keys, restrict logs from storing sensitive input, and use secure channels where appropriate.

7. Patient Rights

Patients may request access to their medical records, ask questions about privacy practices, and report suspected privacy violations through approved channels.

8. Incident Handling

Any suspected disclosure of private information should be reported to the privacy or compliance team. The event should be documented and investigated according to internal policy.

Quick Reference Table

Question	Policy Answer
Can real patient data be used?	No. AI prototypes should not use real patient data or PHI.
Can staff share records with unauthorized people?	No. Patient records must not be shared with unauthorized people.
Where should API keys go?	In environment variables, not hardcoded in code.

Recommended RAG Test Prompts

- Can real patient data be used?
- Can staff share records with unauthorized people?
- Where should API keys go?
- What information is not available in this document?
- Summarize the main rules from this document.

Version: 1.0 | Data Type: Synthetic | Intended Use: Hackathon prototype and RAG demonstration.